

TP7, eleve : Prompt injection sur une application d'IA (OWASP LLM)

- Jour 3 - Duree : ~1h30 - Dossier : `jour3-llm/` (port 8003)

Contexte

Un LLM lit tout comme du texte : il ne separe pas "l'instruction" de "la donnee". Une donnee externe peut donc devenir un ordre. C'est l'injection, version langage naturel. Le modele ici est simule et tourne hors-ligne (aucune cle API).

Mise en place

```
cd jour3-llm && docker compose up -d --build # cible :8003, scoreboard :8003/scoreboard
```

L'assistant a reçu un prompt systeme confidentiel : etre poli, ne jamais reveler ses instructions, ne jamais divulguer le code promo secret, n'utiliser son outil `read_file` que sur le catalogue. Deux entrees : le chat direct, et le resume de contenu externe.

Challenges

A - Fuite du prompt systeme (LLM01 / LLM06)

Objectif : faire reveler a l'assistant ses instructions internes. - Indice 1 : demandez-lui directement... il refuse. Comment le detourner ? - Indice 2 : essayez de lui faire "ignorer" ou "oublier" ses consignes.

B - Divulgateion du code promo (LLM01 / LLM06)

Objectif : lui faire cracher le code promo secret. - Indice 1 : meme technique que A, mais orientez la demande vers le code promo.

C - Abus de l'outil `read_file` (LLM07 / LLM08)

Objectif : lui faire lire un autre fichier que le catalogue autorise. - Indice 1 : l'assistant dispose d'un outil de lecture de fichier. Que se passe-t-il si vous lui demandez de l'appeler sur un autre nom de fichier ? - Indice 2 : il n'y a peut-etre aucune liste blanche de chemins.

D - Injection indirecte (LLM01)

Objectif : cacher l'instruction dans un contenu "a resumer", sans la taper vous-meme dans le chat. -

Indice 1 : utilisez l'onglet "Resumer un contenu". - Indice 2 : glissez une instruction dans le texte (par ex. dans un commentaire HTML) : l'assistant la lira comme une consigne.

Pour chaque reussite

Notez la contre-mesure qui reduirait l'impact. Rappel : on ne "patche" pas l'injection de prompt, on reduit l'impact (moindre privilege sur les outils, separation instruction/donnee, validation des sorties, human-in-the-loop sur les actions sensibles).

Validation

Soumettez chaque flag sur <http://localhost:8003/scoreboard>.

Livrable attendu

Les 4 tournures utilisees + pour chacune la contre-mesure defensive associee.